

- Process controls;
- Financial condition;
- Reputation, including references;
- Degree of reliance on third parties, subcontractors, or partners;
- Legal, regulatory, and compliance history; and
- Ability to meet future needs.
- Monitoring and reporting
 - Measurements and reporting criteria;
 - Right to audit;
 - Third-party reports; and
 - Coordination of responses to security events.
- Transition requirements
 - Initial migration of data to the service provider;
 - Implementation of necessary communications mechanisms;
 - Migration of data from the service provider at termination of contract; and
 - Staff training.
- Contract duration, termination, and assignment
 - Start and term;
 - Conditions and right to cancel;
 - Ownership of data;
 - Timely return of data in machine-readable format;
 - Costs of transition;
 - Limitations, as appropriate, governing assignment to third party;
 - Dispute resolution; and
 - Confidentiality of institution data.
- Contractual protections against liability
 - Indemnification;
 - Limitation of liability; and
 - Insurance.

When outsourcing to a subsidiary or affiliate is considered, management must assure that the components outlined above evidence an arms-length transaction. An arrangement between a financial institution and an affiliate or subsidiary should be on terms that are substantially the same, or at least as favorable to the institution, as those prevailing at the time for comparable transactions with a non-affiliated third party.

Service Provider Selection

Action Summary

Management should:

- Evaluate service provider proposals in light of the institution's needs, including any differences between the institution's solicitation and the service provider proposal;
- Perform due diligence on the prospective service providers;
- Ensure that selection of affiliated parties as service providers is done at arms length in accordance with regulations and guidance issued by the institution's primary regulator; and
- Evaluate foreign-based third-party service providers in light of the guidance found in this section and in Appendix C, Foreign-Based Third-Party Service Providers.

After identifying the work to be performed and the necessary controls, a financial institution solicits responses from prospective service providers. The primary tool for the solicitation is the Request for Proposal (RFP). The RFP also supports subsequent contract negotiations.

Request for Proposal

A financial institution should generate the RFP from the information developed during the requirements definition phase. While the level of detail may vary for any particular procurement, the RFP should describe the institution's objectives; the scope and nature of the work to be performed; the expected production service levels, delivery timelines, measurement requirements, and control measures; and the financial institution's policies

for security, business continuity, and change control. It also requests responses addressing those requirements as well as the fees each service provider will charge.

Once management distributes the RFPs and receives responses, it should evaluate the service provider proposals against the institution's needs. When the institution evaluates the proposals, it may find that the proposals do not completely agree with the RFP. For example, the service the service provider proposes may include different processing workflows or reporting schemes, pricing formulas or techniques, or the response to information requests may not be complete. If the institution considers proposals that differ from the RFP, the institution should evaluate the differences against its requirements and clearly understand how the changes will affect the institution's objectives and service expectations. The institution should evaluate material differences using a process similar to the one used to develop the requirements initially. An institution should negotiate a resolution to any differences between the RFP and the service provider proposal before contracting with a service provider.

Due Diligence

A financial institution should perform due diligence on the service provider's response to an RFP as well as the service provider itself. Due diligence should serve as a verification and analysis tool, providing assurance that the service provider meets the institution's needs. Due diligence should confirm and assess the following information regarding the service provider:

- Existence and corporate history;
- Qualifications, backgrounds, and reputations of company principals, including criminal background checks where appropriate;
- Other companies using similar services from the provider that may be contacted for reference;
- Financial status, including reviews of audited financial statements;
- Strategy and reputation;
- Service delivery capability, status, and effectiveness;
- Technology and systems architecture;
- Internal controls environment, security history, and audit coverage;
- Legal and regulatory compliance including any complaints, litigation, or regulatory actions;
- Reliance on and success in dealing with third party service providers;
- Insurance coverage; and
- Ability to meet disaster recovery and business continuity requirements.

Other important elements include probing for information on intangibles, such as the third party's service philosophies, quality initiatives, and management style. The culture, values, and business styles should fit those of the financial institution. When a foreign-based service provider is considered, the evaluation should assess the relationship in light of the above items as well as the information discussed in Appendix C, Foreign-Based Third-Party Service Providers.

Financial institutions may perform due diligence on one or more of the service providers that respond to the RFP. The depth and formality of the due diligence performed may vary according to the risk of the outsourced relationship, the institution's familiarity with the prospective service providers, and the stage of the provider selection process.

Once institutions issue RFPs, receive and evaluate responses, and perform due diligence, they enter into contract negotiations with one or more of the service providers they have determined can best meet their needs.

Contract Issues

Action Summary

Before signing a contract, management should:

- Ensure the contract clearly defines the rights and responsibilities of both parties;
- Ensure the contract contains adequate and measurable service level agreements;
- Ensure contracts with affiliates clearly reflect an arms-length relationship and costs and services are at least as favorable to the institution as those available from a non-affiliated provider;
- Choose the most appropriate pricing method for the financial institution's needs;
- Ensure the contract does not contain provisions or inducements that may have a significant, adverse affect on the institution;
- Engage legal counsel to review the contract; and
- Evaluate foreign-based third-party service providers in light of the guidance found in this section and in Appendix C, Foreign-Based Third-Party Service Providers.

After selecting a service provider, management should negotiate a contract that meets their requirements. The RFP and the service provider's response can be used as inputs to this process. The contract is the legally binding document that defines all aspects of the servicing relationship. A written contract should be present in all servicing relationships. This includes instances where the service provider is affiliated with the

institution. When contracting with an affiliate, the institution should ensure the costs and quality of services provided are commensurate with those of a nonaffiliated provider. The contract is the single most important control in the outsourcing process. Because of the importance of the contract, management should:

- Verify the accuracy of the description of the outsourcing relationship in the contract;
- Ensure the contract is clearly written and contains sufficient detail to define the rights and responsibilities of each party comprehensively; and
- Engage legal counsel early in the process to help prepare and review the proposed contract.

Examples of contract elements that should be considered include:

Scope of Service. The contract should clearly describe the rights and responsibilities of the parties to the contract. Considerations should include:

- Descriptions of required activities, timeframes for their implementation, and assignment of responsibilities. Implementation provisions should take into consideration other existing systems or interrelated systems to be developed by different service providers (e.g., an Internet banking system being integrated with existing core applications or systems customization);
- Obligations of, and services to be performed by, the service provider including software support and maintenance, training of employees, or customer service;
- Obligations of the financial institution;
- The contracting parties' rights in modifying existing services performed under the contract; and
- Guidelines for adding new or different services and for contract re-negotiation.

Performance Standards. Institutions should include performance standards that define minimum service level requirements and remedies for failure to meet standards in the contract. For example, common service level metrics include percent system uptime, deadlines for completing batch processing, or number of processing errors. Industry standards for service levels may provide a reference point. The institution should periodically review overall performance standards to ensure consistency with its goals and objectives. Also see the Service Level Agreements section in this booklet.

Security and Confidentiality. The contract should address the service provider's responsibility for security and confidentiality of the institution's resources (e.g., information, hardware). ^[4] The agreement should prohibit the service provider and its agents from using or disclosing the institution's information, except as necessary to or consistent with providing the contracted services, and to protect against unauthorized use (e.g., disclosure of information to institution competitors). If the service provider

receives nonpublic personal information regarding the institution's customers, the institution should verify that the service provider complies with all applicable requirements of the privacy regulations. Institutions should require the service provider to fully disclose breaches in security resulting in unauthorized intrusions into the service provider that may materially affect the institution or its customers. The service provider should report to the institution when intrusions occur, the effect on the institution, and corrective action to respond to the intrusion, based on agreements between both parties.

Controls. Management should consider implementing contract provisions that address the following controls:

- Service provider internal controls;
- Compliance with applicable regulatory requirements;
- Record maintenance requirements for the service provider;
- Access to the records by the institution;
- Notification requirements and approval rights for any material changes to services, systems, controls, key project personnel, and service locations;
- Setting and monitoring parameters for financial functions including payments processing or extensions of credit on behalf of the institution; and
- Insurance coverage maintained by the service provider.

Audit. The institution should include in the contract the types of audit reports it is entitled to receive (e.g., financial, internal control, and security reviews). The contract should specify the audit frequency, any charges for obtaining the audits, as well as the rights of the institution and its regulatory agencies to obtain the results of the audits in a timely manner. The contract may also specify rights to obtain documentation of the resolution of any deficiencies and to inspect the processing facilities and operating practices of the service provider. Management should consider, based upon the risk assessment phase, if it can rely on internal audits or if there is a need for external audits and reviews.

For services involving access to open networks, such as Internet-related services, management should pay special attention to security. The institution should consider including contract terms requiring periodic control reviews performed by an independent party with sufficient expertise. These reviews may include penetration testing, intrusion detection, reviews of firewall configuration, and other independent control reviews. The institution should receive sufficiently detailed reports on the findings of these ongoing audits to assess security adequately without compromising the service provider's security.

Reports. Contractual terms should include the frequency and type of reports the institution will receive (e.g., performance reports, control audits, financial statements, security, and business resumption testing reports). The contracts should also outline the guidelines and fees for obtaining custom reports.

Business Resumption and Contingency Plans. The contract should address the service provider's responsibility for backup and record protection, including equipment, program

and data files, and maintenance of disaster recovery and contingency plans. The contracts should outline the service provider's responsibility to test the plans regularly and provide the results to the institution. The institution should consider interdependencies among service providers when determining business resumption testing requirements. The service provider should provide the institution a copy of the contingency plan that outlines the required operating procedures in the event of business disruption. Contracts should include specific provisions for business recovery timeframes that meet the institution's business requirements. The institution should ensure that the contract does not contain any provisions that would excuse the service provider from implementing its contingency plans.

Sub-contracting and Multiple Service Provider Relationships. Some service providers may contract with third parties in providing services to the financial institution. Institutions should be aware of and approve all subcontractors. To provide accountability, the financial institution should designate the primary contracting service provider in the contract. The contract should also specify that the primary contracting service provider is responsible for the services outlined in the contract regardless of which entity actually conducts the operations. The institution should also consider including notification and approval requirements regarding changes to the service provider's significant subcontractors.

Cost. The contract should fully describe the calculation of fees for base services, including any development, conversion, and recurring services, as well as any charges based upon volume of activity or for special requests. Contracts should also address the responsibility and additional cost for purchasing and maintaining hardware and software. Any conditions under which the cost structure may be changed should be addressed in detail including limits on any cost increases. Also see the Pricing Methods and Bundling sections in this booklet.

Ownership and License. The contract should address the ownership, rights to, and allowable use of the institution's data, equipment/hardware, system documentation, system and application software, and other intellectual property rights. Ownership of the institution's data must rest clearly with the institution. Other intellectual property rights may include the institution's name and logo, its trademark or copyrighted material, domain names, web sites designs, and other work products developed by the service provider for the institution. Additional information regarding the development of customized software to support outsourced services can be found in the IT Handbook's "Development and Acquisition Booklet."

Duration. Institutions should consider the type of technology and current state of the industry when negotiating the appropriate length of the contract and its renewal periods. While there can be benefits to long-term technology contracts, certain technologies may be subject to rapid change and a shorter-term contract may prove beneficial. Similarly, institutions should consider the appropriate length of time required to notify the service provider of the institutions' intent not to renew the contract prior to expiration. Institutions should consider coordinating the expiration dates of contracts for inter-related services (e.g., web site, telecommunications, programming, network support) so that they coincide, where practical. Such coordination can minimize the risk of terminating a contract early and incurring penalties as a result of necessary termination of another related service contract.

Dispute Resolution. The institution should consider including a provision for a dispute resolution process that attempts to resolve problems in an expeditious manner as well as a provision for continuation of services during the dispute resolution period.

Indemnification. Indemnification provisions should require the service provider to hold the financial institution harmless from liability for the negligence of the service provider. Legal counsel should review these provisions to ensure the institution will not be held liable for claims arising as a result of the negligence of the service provider.

Limitation of Liability. Some service provider standard contracts may contain clauses limiting the amount of liability that can be incurred by the service provider. If the institution is considering such a contract, management should assess whether the damage limitation bears an adequate relationship to the amount of loss the financial institution might reasonably experience as a result of the service provider's failure to perform its obligations.

Termination. Management should assess the timeliness and expense of contract termination provisions. The extent and flexibility of termination rights can vary depending upon the service. Institutions should consider including termination rights for a variety of conditions including change in control (e.g., acquisitions and mergers), convenience, substantial increase in cost, repeated failure to meet service levels, failure to provide critical services, bankruptcy, company closure, and insolvency. The contract should establish notification and timeframe requirements and provide for the timely return of the institution's data and resources in a machine readable format upon termination. Any costs associated with conversion assistance should also be clearly stated.

Assignment. The institution should consider contract provisions that prohibit assignment of the contract to a third party without the institution's consent. Assignment provisions should also reflect notification requirements for any changes to material subcontractors.

Foreign-based service providers. Institutions entering into contracts with foreign-based service providers should consider a number of additional contract issues and provisions. See Appendix C included in this booklet.

Regulatory Compliance. Financial institutions should ensure that contracts with service providers include an agreement that the service provider and its services will comply with applicable regulatory guidance and requirements. The provision should also indicate that the service provider agrees to provide accurate information and timely access to the appropriate regulatory agencies based on the type and level of service it provides to the financial institution.

Service Level Agreements (SLAs)

Service level agreements are formal documents that outline the institution's pre-determined requirements for the service and establish incentives to meet, or penalties for failure to meet, the requirements. Financial institutions should link SLAs to provisions in the contract regarding incentives, penalties, and contract cancellation in order to protect themselves against service provider performance failures.

Management should develop SLAs by first identifying the significant elements of the

service. The elements can be related to tasks (i.e., processing error rates, system up-time, etc.) or they can be organizational (i.e., employee turnover). Once it has identified the elements, management should devise ways to measure the performance of those elements objectively. Finally, institutions should determine the frequency of the measurements and an acceptable range of results to determine when a service provider violates the SLA benchmarks.

Although the specific performance standards may vary with the nature of the service delivered, management should consider SLAs to address the following issues:

- Availability and timeliness of services;
- Confidentiality and integrity of data;
- Change control;
- Security standards compliance, including vulnerability and penetration management;
- Business continuity compliance; and
- Help desk support.

SLAs addressing business continuity should measure the service provider's or vendor's contractual responsibility for backup, record retention, data protection, and the maintenance of disaster recovery and contingency plans. The SLAs can also test the contingency plan's provisions for business recovery timeframes or conducting periodic tests of the plan. Neither contracts nor SLAs should contain any extraordinary provisions that would excuse the vendor or service provider from implementing its contingency plans (outsourcing contracts should include clauses that discuss unforeseen events for which the institution would not be able to adequately prepare).

Pricing Methods

Financial institutions should have several choices when it comes to pricing an outsourcing venture. Management should consider all available pricing options and choose the most appropriate for the specific contract. Examples of different pricing methods include:

- **Cost plus**-The service provider receives payment for its actual costs, plus a predetermined profit margin or markup (usually percentage of actual costs). For example, the service provider builds a website at a cost of \$5,000 plus a 10% markup; the institution pays \$5,500.
- **Fixed price**-The service provider price is the same for each billing cycle for the entire contract period. The advantage of this approach is that institutions know exactly what the provider will bill each month. Problems may arise if the institution does not adequately define the scope or the process. Often, with the fixed price method, the service provider labels services beyond the defined scope as additional or premium

services. For example, if a service provider bills an institution \$500 per month for maintaining a website, and the institution decides it wants to add another link, the service provider may charge more for that service if it is not clearly defined in the original contract.

- **Unit pricing**-The service provider sets a rate for a particular level of service, and the institution pays based on usage. For example, if an institution pays \$.10 per hit on a website, and the site has 5,000 hits for the month, the institution pays \$500 for the month.
- **Variable pricing**-The service provider establishes the price of the service based on a variable such as system availability. For example, the provider bills the institution \$500, \$600, or \$800 per month for service levels of 99.00, 99.50, or 99.75 percent system availability, respectively. If a website was available 99.80 percent of the time in a billing period, the institution would pay \$800.
- **Incentive-based pricing**-Incentives encourage the service provider to perform at peak level by offering a bonus if the provider performs well. This plan can also require the provider to pay a penalty for not performing at an acceptable level. For example, the institution wants a service provider to build a website. The service provider agrees to do so within 90 days for \$5,000. The institution offers the provider \$6,500 if the website is ready within 45 days, but states that it will only pay \$3,500 if the provider fails to meet its 90 day deadline.
- **Future price changes**-Service providers typically include a provision that will increase costs in the future either by a specified percentage or per unit. Some institutions may also identify circumstances under which price reductions might be warranted (i.e., reduction in equipment costs).

Bundling

The provider may entice the institution to purchase more than one system, process, or service for a single price - referred to as "bundling." This practice may result in the institution getting a single consolidated bill that may not provide information relating to pricing for each specific system, process, or service. Although the bundled services may appear to be cheaper, the institution cannot analyze the costs of the individual services. Bundles may include processes and services that the institution does not want or need. It also may not allow the institution to discontinue a specific system, process, or service without having to renegotiate the contract for all remaining services.

Contract Inducement Concerns

Financial institutions should not sign servicing contracts that contain provisions or inducements that may adversely affect the institution. Such contract provisions may include extended terms (up to 10 years), significant increases in costs after the first few years, and/or substantial cancellation penalties. In addition, some service contracts improperly offer inducements that allow an institution to retain or increase capital by deferring losses on the disposition of assets or avoiding expense recognition. These inducements may attract institutions wanting to mask capital problems.

Inducements can take several forms including the following examples: